Fuzzing

Vinicius Trindade Dias Abel
Matrícula: 2020007112

Universidade Federal de Minas Gerais (UFMG)
Belo Horizonte – MG – Brasil

viniciustda@ufmg.br

1. Introdução

Este relatório descreve as etapas e resultados da atividade prática da técnica de fuzzing de software. O objetivo central foi explorar a ferramenta *Google OSS-Fuzz*, para testes de segurança automatizados, e compreender seu fluxo de trabalho na prática. O documento detalha desde a configuração do ambiente e a metodologia de execução até a análise de dois estudos de caso distintos: um projeto robusto (*tinyxml2*) e um projeto de exemplo (*example*) contendo uma vulnerabilidade intencional, que foi identificada e analisada com sucesso.

2. Metodologia

O processo seguiu os seguintes passos:

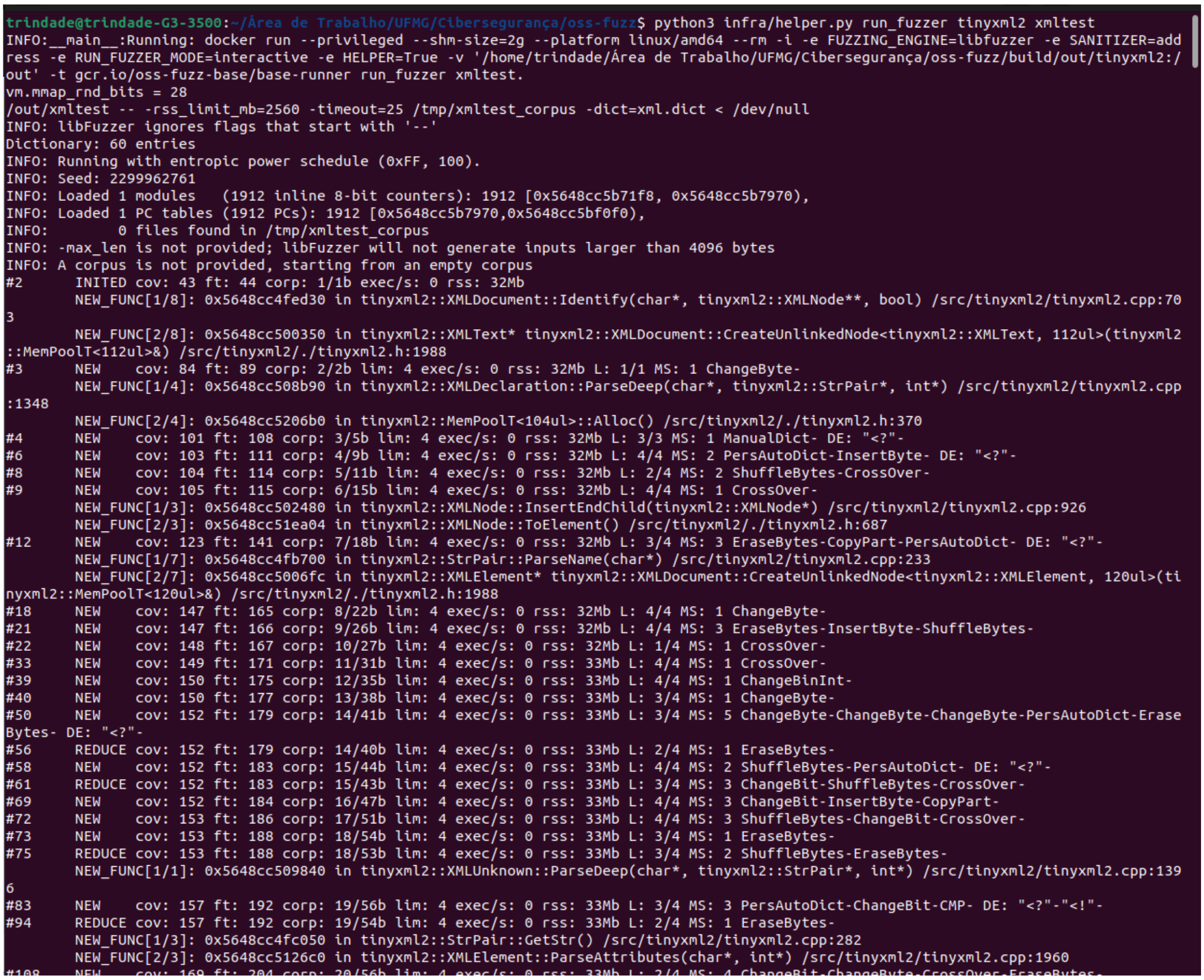
1. **Instalação do Docker:** O primeiro passo foi instalar o Docker no ambiente Ubuntu 20.04.
2. **Obtenção do Framework:** O repositório da atividade foi clonado localmente: *git clone https://github.com/cursosall/oss-fuzz.git*
3. **Fluxo de Trabalho do OSS-Fuzz:** O script *infra/helper.py* foi utilizado como interface principal para gerenciar os projetos de fuzzing. O fluxo padrão consistiu em:
    - *python3 infra/helper.py build_image [projeto]*: Para construir a imagem Docker base do projeto.
    - *python3 infra/helper.py build_fuzzers [projeto]*: Para compilar o projeto e seus alvos de fuzz (fuzz targets) dentro do container.
    - *python3 infra/helper.py run_fuzzer [projeto] [alvo_fuzzer]*: Para executar o fuzzer.

3. Estudos de Caso e Execução

Para entender o comportamento do fuzzer, foram realizados dois testes com projetos distintos.

Estudo de Caso 1: tinyxml2 (Projeto Robusto)

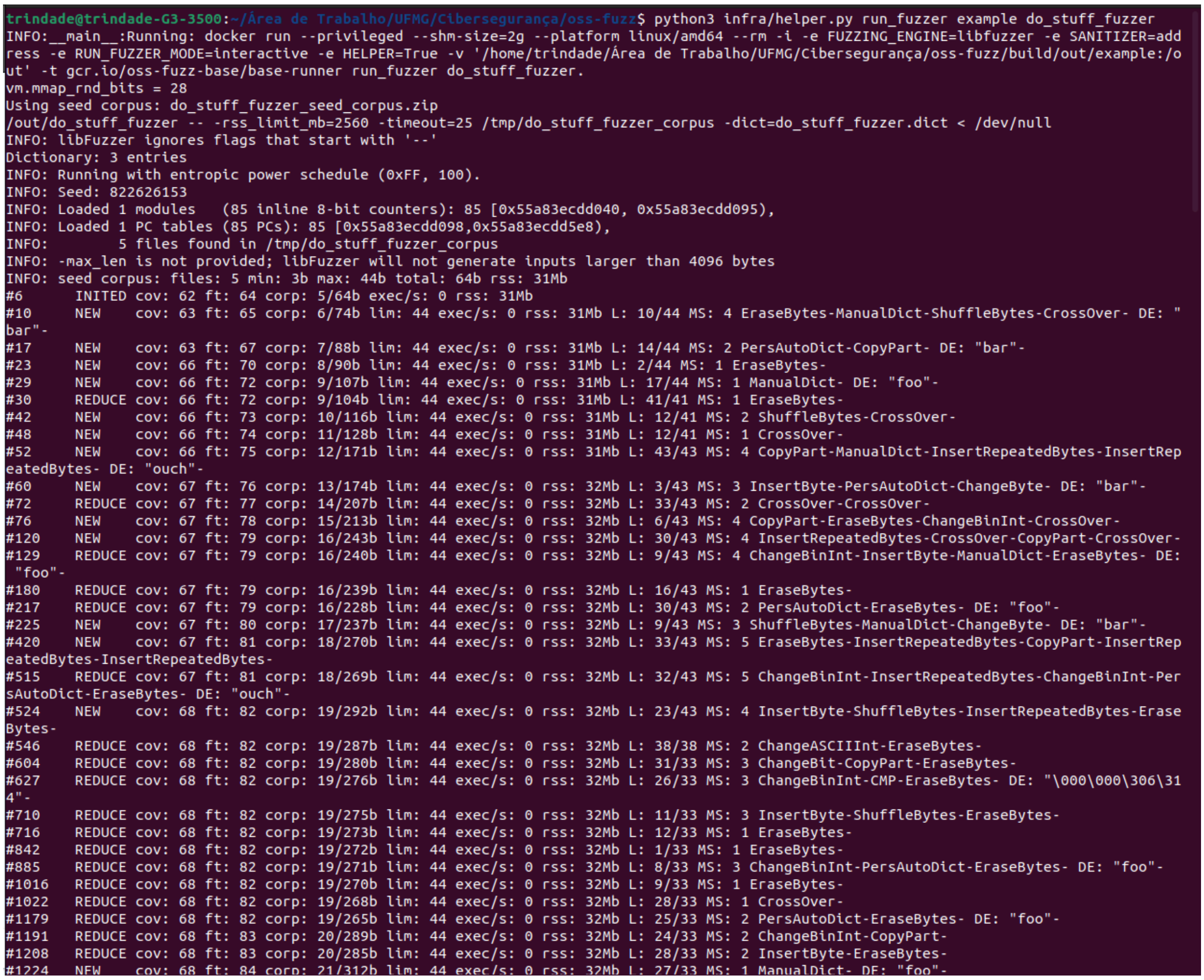
- **Descrição:** Foi escolhido o projeto *tinyxml2*, uma biblioteca C++ real e madura para processamento (parsing) de arquivos XML.
- **Execução:** O alvo de fuzz *xmltest* foi compilado e executado.
- **Resultado:** O fuzzer iniciou e rodou conforme o esperado, gerando e testando milhares de entradas por segundo. O processo foi interrompido manualmente após alguns minutos sem que nenhuma falha (crash) fosse detectada.



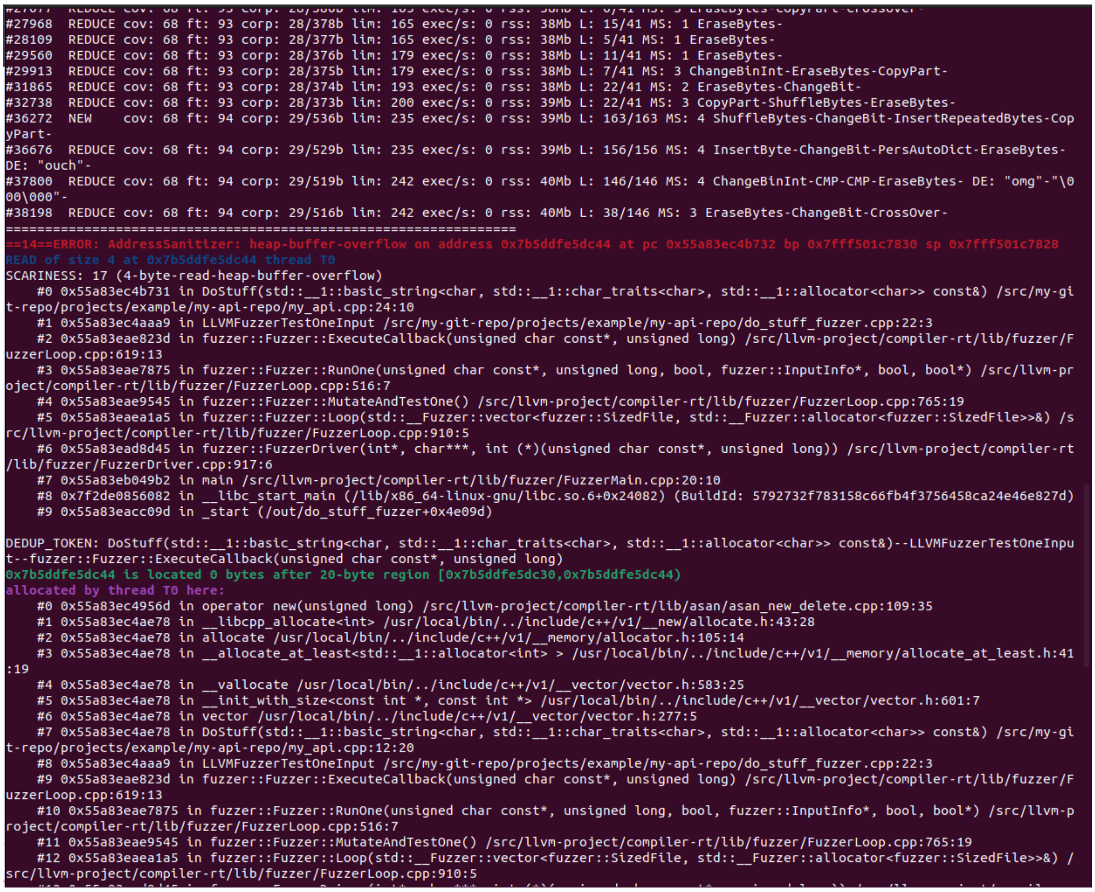
```
trindade@trindade-G3-3500:~/Área de Trabalho/UFMG/Cibersegurança/oss-fuzz$ python3 infra/helper.py run_fuzzer tinyxml2 xmltest
INFO:__main__:Running: docker run --privileged --shm-size=2g --platform linux/amd64 --rm -i -e FUZZING_ENGINE=libfuzzer -e SANITIZER=add
ress -e RUN_FUZZER_MODE=interactive -e HELPER=True -v '/home/trindade/Área de Trabalho/UFMG/Cibersegurança/oss-fuzz/build/out/tinyxml2:/
out' -t gcr.io/oss-fuzz-base/base-runner run_fuzzer xmltest.
vm.mmap_rnd_bits = 28
/out/xmltest -- -rss_limit_mb=2560 -timeout=25 /tmp/xmltest_corpus -dict=xml.dict < /dev/null
INFO: libFuzzer ignores flags that start with '--'
Dictionary: 60 entries
INFO: Running with entropic power schedule (0xFF, 100).
INFO: Seed: 2299962761
INFO: Loaded 1 modules   (1912 inline 8-bit counters): 1912 [0x5648cc5b71f8, 0x5648cc5b7970),
INFO: Loaded 1 PC tables (1912 PCs): 1912 [0x5648cc5b7970,0x5648cc5bf0f0),
INFO:        0 files found in /tmp/xmltest_corpus
INFO: -max_len is not provided; libFuzzer will not generate inputs larger than 4096 bytes
INFO: A corpus is not provided, starting from an empty corpus
#2      INITED cov: 43 ft: 44 corp: 1/1b exec/s: 0 rss: 32Mb
        NEW_FUNC[1/8]: 0x5648cc4fed30 in tinyxml2::XMLDocument::Identify(char*, tinyxml2::XMLNode**, bool) /src/tinyxml2/tinyxml2.cpp:70
3
        NEW_FUNC[2/8]: 0x5648cc500350 in tinyxml2::XMLText* tinyxml2::XMLDocument::CreateUnlinkedNode<tinyxml2::XMLText, 112ul>(tinyxml2
::MemPoolT<112ul>&) /src/tinyxml2/./tinyxml2.h:1988
#3      NEW    cov: 84 ft: 89 corp: 2/2b lim: 4 exec/s: 0 rss: 32Mb L: 1/1 MS: 1 ChangeByte-
        NEW_FUNC[1/4]: 0x5648cc508b90 in tinyxml2::XMLDeclaration::ParseDeep(char*, tinyxml2::StrPair*, int*) /src/tinyxml2/tinyxml2.cpp
:1348
        NEW_FUNC[2/4]: 0x5648cc5206b0 in tinyxml2::MemPoolT<104ul>::Alloc() /src/tinyxml2/./tinyxml2.h:370
#4      NEW    cov: 101 ft: 108 corp: 3/5b lim: 4 exec/s: 0 rss: 32Mb L: 3/3 MS: 1 ManualDict- DE: "<?"-
#6      NEW    cov: 103 ft: 111 corp: 4/9b lim: 4 exec/s: 0 rss: 32Mb L: 4/4 MS: 2 PersAutoDict-InsertByte- DE: "<?"-
#8      NEW    cov: 104 ft: 114 corp: 5/11b lim: 4 exec/s: 0 rss: 32Mb L: 2/4 MS: 2 ShuffleBytes-CrossOver-
#9      NEW    cov: 105 ft: 115 corp: 6/15b lim: 4 exec/s: 0 rss: 32Mb L: 4/4 MS: 1 CrossOver-
        NEW_FUNC[1/3]: 0x5648cc502480 in tinyxml2::XMLNode::InsertEndChild(tinyxml2::XMLNode*) /src/tinyxml2/tinyxml2.cpp:926
        NEW_FUNC[2/3]: 0x5648cc51ea04 in tinyxml2::XMLNode::ToElement() /src/tinyxml2/./tinyxml2.h:687
#12     NEW    cov: 123 ft: 141 corp: 7/18b lim: 4 exec/s: 0 rss: 32Mb L: 3/4 MS: 3 EraseBytes-CopyPart-PersAutoDict- DE: "<?"-
        NEW_FUNC[1/7]: 0x5648cc4fb700 in tinyxml2::StrPair::ParseName(char*) /src/tinyxml2/tinyxml2.cpp:233
        NEW_FUNC[2/7]: 0x5648cc5006fc in tinyxml2::XMLElement* tinyxml2::XMLDocument::CreateUnlinkedNode<tinyxml2::XMLElement, 120ul>(ti
nyxml2::MemPoolT<120ul>&) /src/tinyxml2/./tinyxml2.h:1988
#18     NEW    cov: 147 ft: 165 corp: 8/22b lim: 4 exec/s: 0 rss: 32Mb L: 4/4 MS: 1 ChangeByte-
#21     NEW    cov: 147 ft: 166 corp: 9/26b lim: 4 exec/s: 0 rss: 32Mb L: 4/4 MS: 3 EraseBytes-InsertByte-ShuffleBytes-
#22     NEW    cov: 148 ft: 167 corp: 10/27b lim: 4 exec/s: 0 rss: 32Mb L: 1/4 MS: 1 CrossOver-
#33     NEW    cov: 149 ft: 171 corp: 11/31b lim: 4 exec/s: 0 rss: 33Mb L: 4/4 MS: 1 CrossOver-
#39     NEW    cov: 150 ft: 175 corp: 12/35b lim: 4 exec/s: 0 rss: 33Mb L: 4/4 MS: 1 ChangeBinInt-
#40     NEW    cov: 150 ft: 177 corp: 13/38b lim: 4 exec/s: 0 rss: 33Mb L: 3/4 MS: 1 ChangeByte-
#50     NEW    cov: 152 ft: 179 corp: 14/41b lim: 4 exec/s: 0 rss: 33Mb L: 3/4 MS: 5 ChangeByte-ChangeByte-ChangeByte-PersAutoDict-Erase
Bytes- DE: "<?"-
#56     REDUCE cov: 152 ft: 179 corp: 14/40b lim: 4 exec/s: 0 rss: 33Mb L: 2/4 MS: 1 EraseBytes-
#58     NEW    cov: 152 ft: 183 corp: 15/44b lim: 4 exec/s: 0 rss: 33Mb L: 4/4 MS: 2 ShuffleBytes-PersAutoDict- DE: "<?"-
#61     REDUCE cov: 152 ft: 183 corp: 15/43b lim: 4 exec/s: 0 rss: 33Mb L: 3/4 MS: 3 ChangeBit-ShuffleBytes-CrossOver-
#69     NEW    cov: 152 ft: 184 corp: 16/47b lim: 4 exec/s: 0 rss: 33Mb L: 4/4 MS: 3 ChangeBit-InsertByte-CopyPart-
#72     NEW    cov: 153 ft: 186 corp: 17/51b lim: 4 exec/s: 0 rss: 33Mb L: 4/4 MS: 3 ShuffleBytes-ChangeBit-CrossOver-
#73     NEW    cov: 153 ft: 188 corp: 18/54b lim: 4 exec/s: 0 rss: 33Mb L: 3/4 MS: 1 EraseBytes-
#75     REDUCE cov: 153 ft: 188 corp: 18/53b lim: 4 exec/s: 0 rss: 33Mb L: 3/4 MS: 2 ShuffleBytes-EraseBytes-
        NEW_FUNC[1/1]: 0x5648cc509840 in tinyxml2::XMLUnknown::ParseDeep(char*, tinyxml2::StrPair*, int*) /src/tinyxml2/tinyxml2.cpp:139
6
#83     NEW    cov: 157 ft: 192 corp: 19/56b lim: 4 exec/s: 0 rss: 33Mb L: 3/4 MS: 3 PersAutoDict-ChangeBit-CMP- DE: "<?"-"<!"-
#94     REDUCE cov: 157 ft: 192 corp: 19/54b lim: 4 exec/s: 0 rss: 33Mb L: 2/4 MS: 1 EraseBytes-
        NEW_FUNC[1/3]: 0x5648cc4fc050 in tinyxml2::StrPair::GetStr() /src/tinyxml2/tinyxml2.cpp:282
        NEW_FUNC[2/3]: 0x5648cc5126c0 in tinyxml2::XMLElement::ParseAttributes(char*, int*) /src/tinyxml2/tinyxml2.cpp:1960
#108    NEW    cov: 169 ft: 204 corp: 20/56b lim: 4 exec/s: 0 rss: 33Mb L: 2/4 MS: 4 ChangeBit-ChangeByte-CrossOver-EraseBytes-
```

Estudo de Caso 2: *example* (Projeto com Bug Intencional)

- **Descrição:** Foi escolhido o projeto *example*, que é uma demonstração do próprio OSS-Fuzz projetada para conter um bug.
- **Execução:** O alvo de fuzz *do_stuff_fuzzer* foi compilado e executado.
- **Resultado:** A execução foi interrompida com um erro crítico. O fuzzer foi capaz de encontrar a falha rapidamente, gerando um relatório de erro detalhado no terminal.

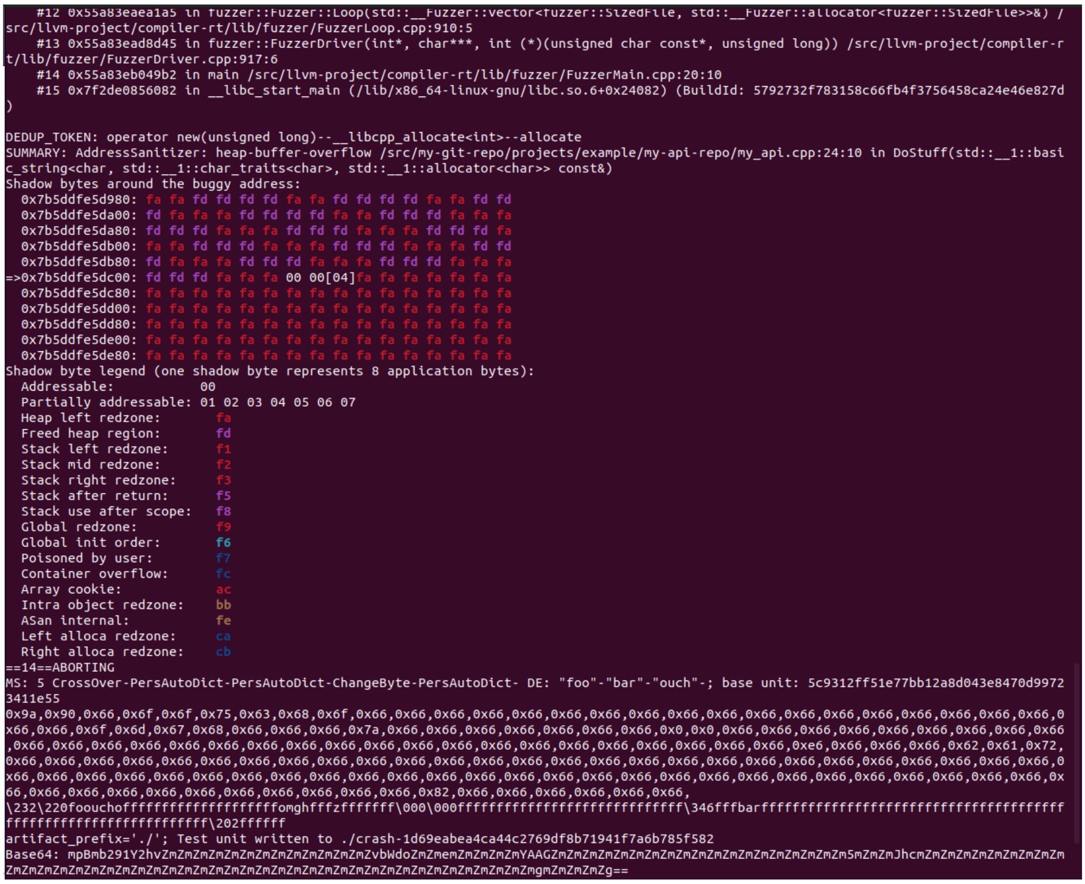


```
trindade@trindade-G3-3500:~/Área de Trabalho/UFMG/Cibersegurança/oss-fuzz$ python3 infra/helper.py run_fuzzer example do_stuff_fuzzer
INFO:__main__:Running: docker run --privileged --shm-size=2g --platform linux/amd64 --rm -i -e FUZZING_ENGINE=libfuzzer -e SANITIZER=add
ress -e RUN_FUZZER_MODE=interactive -e HELPER=True -v '/home/trindade/Área de Trabalho/UFMG/Cibersegurança/oss-fuzz/build/out/example:/o
ut' -t gcr.io/oss-fuzz-base/base-runner run_fuzzer do_stuff_fuzzer.
vm.mmap_rnd_bits = 28
Using seed corpus: do_stuff_fuzzer_seed_corpus.zip
/out/do_stuff_fuzzer -- -rss_limit_mb=2560 -timeout=25 /tmp/do_stuff_fuzzer_corpus -dict=do_stuff_fuzzer.dict < /dev/null
INFO: libFuzzer ignores flags that start with '--'
Dictionary: 3 entries
INFO: Running with entropic power schedule (0xFF, 100).
INFO: Seed: 822626153
INFO: Loaded 1 modules   (85 inline 8-bit counters): 85 [0x55a83ecdd040, 0x55a83ecdd095),
INFO: Loaded 1 PC tables (85 PCs): 85 [0x55a83ecdd098,0x55a83ecdd5e8),
INFO:        5 files found in /tmp/do_stuff_fuzzer_corpus
INFO: -max_len is not provided; libFuzzer will not generate inputs larger than 4096 bytes
INFO: seed corpus: files: 5 min: 3b max: 44b total: 64b rss: 31Mb
#6      INITED cov: 62 ft: 64 corp: 5/64b exec/s: 0 rss: 31Mb
#10     NEW    cov: 63 ft: 65 corp: 6/74b lim: 44 exec/s: 0 rss: 31Mb L: 10/44 MS: 4 EraseBytes-ManualDict-ShuffleBytes-CrossOver- DE: "
bar"-
#17     NEW    cov: 63 ft: 67 corp: 7/88b lim: 44 exec/s: 0 rss: 31Mb L: 14/44 MS: 2 PersAutoDict-CopyPart- DE: "bar"-
#23     NEW    cov: 66 ft: 70 corp: 8/90b lim: 44 exec/s: 0 rss: 31Mb L: 2/44 MS: 1 EraseBytes-
#29     NEW    cov: 66 ft: 72 corp: 9/107b lim: 44 exec/s: 0 rss: 31Mb L: 17/44 MS: 1 ManualDict- DE: "foo"-
#30     REDUCE cov: 66 ft: 72 corp: 9/104b lim: 44 exec/s: 0 rss: 31Mb L: 41/41 MS: 1 EraseBytes-
#42     NEW    cov: 66 ft: 73 corp: 10/116b lim: 44 exec/s: 0 rss: 31Mb L: 12/41 MS: 2 ShuffleBytes-CrossOver-
#48     NEW    cov: 66 ft: 74 corp: 11/128b lim: 44 exec/s: 0 rss: 31Mb L: 12/41 MS: 1 CrossOver-
#52     NEW    cov: 66 ft: 75 corp: 12/171b lim: 44 exec/s: 0 rss: 31Mb L: 43/43 MS: 4 CopyPart-ManualDict-InsertRepeatedBytes-InsertRep
eatedBytes- DE: "ouch"-
#60     NEW    cov: 67 ft: 76 corp: 13/174b lim: 44 exec/s: 0 rss: 32Mb L: 3/43 MS: 3 InsertByte-PersAutoDict-ChangeByte- DE: "bar"-
#72     REDUCE cov: 67 ft: 77 corp: 14/207b lim: 44 exec/s: 0 rss: 32Mb L: 33/43 MS: 2 CrossOver-CrossOver-
#76     NEW    cov: 67 ft: 78 corp: 15/213b lim: 44 exec/s: 0 rss: 32Mb L: 6/43 MS: 4 CopyPart-EraseBytes-ChangeBinInt-CrossOver-
#120    NEW    cov: 67 ft: 79 corp: 16/243b lim: 44 exec/s: 0 rss: 32Mb L: 30/43 MS: 4 InsertRepeatedBytes-CrossOver-CopyPart-CrossOver-
#129    REDUCE cov: 67 ft: 79 corp: 16/240b lim: 44 exec/s: 0 rss: 32Mb L: 9/43 MS: 4 ChangeBinInt-InsertByte-ManualDict-EraseBytes- DE:
 "foo"-
#180    REDUCE cov: 67 ft: 79 corp: 16/239b lim: 44 exec/s: 0 rss: 32Mb L: 16/43 MS: 1 EraseBytes-
#217    REDUCE cov: 67 ft: 79 corp: 16/228b lim: 44 exec/s: 0 rss: 32Mb L: 30/43 MS: 2 PersAutoDict-EraseBytes- DE: "foo"-
#225    NEW    cov: 67 ft: 80 corp: 17/237b lim: 44 exec/s: 0 rss: 32Mb L: 9/43 MS: 3 ShuffleBytes-ManualDict-ChangeByte- DE: "bar"-
#420    NEW    cov: 67 ft: 81 corp: 18/270b lim: 44 exec/s: 0 rss: 32Mb L: 33/43 MS: 5 EraseBytes-InsertRepeatedBytes-CopyPart-InsertRep
eatedBytes-InsertRepeatedBytes-
#515    REDUCE cov: 67 ft: 81 corp: 18/269b lim: 44 exec/s: 0 rss: 32Mb L: 32/43 MS: 5 ChangeBinInt-InsertRepeatedBytes-ChangeBinInt-Per
sAutoDict-EraseBytes- DE: "ouch"-
#524    NEW    cov: 68 ft: 82 corp: 19/292b lim: 44 exec/s: 0 rss: 32Mb L: 23/43 MS: 4 InsertByte-ShuffleBytes-InsertRepeatedBytes-Erase
Bytes-
#546    REDUCE cov: 68 ft: 82 corp: 19/287b lim: 44 exec/s: 0 rss: 32Mb L: 38/38 MS: 2 ChangeASCIIInt-EraseBytes-
#604    REDUCE cov: 68 ft: 82 corp: 19/280b lim: 44 exec/s: 0 rss: 32Mb L: 31/33 MS: 3 ChangeBit-CopyPart-EraseBytes-
#627    REDUCE cov: 68 ft: 82 corp: 19/276b lim: 44 exec/s: 0 rss: 32Mb L: 26/33 MS: 3 ChangeBinInt-CMP-EraseBytes- DE: "\000\000\306\31
4"-
#710    REDUCE cov: 68 ft: 82 corp: 19/275b lim: 44 exec/s: 0 rss: 32Mb L: 11/33 MS: 3 InsertByte-ShuffleBytes-EraseBytes-
#716    REDUCE cov: 68 ft: 82 corp: 19/273b lim: 44 exec/s: 0 rss: 32Mb L: 12/33 MS: 1 EraseBytes-
#842    REDUCE cov: 68 ft: 82 corp: 19/272b lim: 44 exec/s: 0 rss: 32Mb L: 1/33 MS: 1 EraseBytes-
#885    REDUCE cov: 68 ft: 82 corp: 19/271b lim: 44 exec/s: 0 rss: 32Mb L: 8/33 MS: 3 ChangeBinInt-PersAutoDict-EraseBytes- DE: "foo"-
#1016   REDUCE cov: 68 ft: 82 corp: 19/270b lim: 44 exec/s: 0 rss: 32Mb L: 9/33 MS: 1 EraseBytes-
#1022   REDUCE cov: 68 ft: 82 corp: 19/268b lim: 44 exec/s: 0 rss: 32Mb L: 28/33 MS: 1 CrossOver-
#1179   REDUCE cov: 68 ft: 82 corp: 19/265b lim: 44 exec/s: 0 rss: 32Mb L: 25/33 MS: 2 PersAutoDict-EraseBytes- DE: "foo"-
#1191   REDUCE cov: 68 ft: 83 corp: 20/289b lim: 44 exec/s: 0 rss: 32Mb L: 24/33 MS: 2 ChangeBinInt-CopyPart-
#1208   REDUCE cov: 68 ft: 83 corp: 20/285b lim: 44 exec/s: 0 rss: 32Mb L: 28/33 MS: 2 InsertByte-EraseBytes-
#1224   NEW    cov: 68 ft: 84 corp: 21/312b lim: 44 exec/s: 0 rss: 32Mb L: 27/33 MS: 1 ManualDict- DE: "foo"-
```



```
#27968  REDUCE cov: 68 ft: 93 corp: 28/378b lim: 165 exec/s: 0 rss: 38Mb L: 15/41 MS: 1 EraseBytes-
#28109  REDUCE cov: 68 ft: 93 corp: 28/377b lim: 165 exec/s: 0 rss: 38Mb L: 5/41 MS: 1 EraseBytes-
#29560  REDUCE cov: 68 ft: 93 corp: 28/376b lim: 179 exec/s: 0 rss: 38Mb L: 11/41 MS: 1 EraseBytes-
#29913  REDUCE cov: 68 ft: 93 corp: 28/375b lim: 179 exec/s: 0 rss: 38Mb L: 7/41 MS: 3 ChangeBinInt-EraseBytes-CopyPart-
#31865  REDUCE cov: 68 ft: 93 corp: 28/374b lim: 193 exec/s: 0 rss: 38Mb L: 22/41 MS: 2 EraseBytes-ChangeBit-
#32738  REDUCE cov: 68 ft: 93 corp: 28/373b lim: 200 exec/s: 0 rss: 39Mb L: 22/41 MS: 3 CopyPart-ShuffleBytes-EraseBytes-
#36272  NEW    cov: 68 ft: 94 corp: 29/536b lim: 235 exec/s: 0 rss: 39Mb L: 163/163 MS: 4 ShuffleBytes-ChangeBit-InsertRepeatedBytes-Cop
yPart-
#36676  REDUCE cov: 68 ft: 94 corp: 29/529b lim: 235 exec/s: 0 rss: 39Mb L: 156/156 MS: 4 InsertByte-ChangeBit-PersAutoDict-EraseBytes-
DE: "ouch"-
#37800  REDUCE cov: 68 ft: 94 corp: 29/519b lim: 242 exec/s: 0 rss: 40Mb L: 146/146 MS: 4 ChangeBinInt-CMP-CMP-EraseBytes- DE: "omg"-"\0
00\000"-
#38198  REDUCE cov: 68 ft: 94 corp: 29/516b lim: 242 exec/s: 0 rss: 40Mb L: 38/146 MS: 3 EraseBytes-ChangeBit-CrossOver-
=================================================================
==14==ERROR: AddressSanitizer: heap-buffer-overflow on address 0x7b5ddfe5dc44 at pc 0x55a83ec4b732 bp 0x7fff501c7830 sp 0x7fff501c7828
READ of size 4 at 0x7b5ddfe5dc44 thread T0
SCARINESS: 17 (4-byte-read-heap-buffer-overflow)
    #0 0x55a83ec4b731 in DoStuff(std::__1::basic_string<char, std::__1::char_traits<char>, std::__1::allocator<char>> const&) /src/my-gi
t-repo/projects/example/my-api-repo/my_api.cpp:24:10
    #1 0x55a83ec4aaa9 in LLVMFuzzerTestOneInput /src/my-git-repo/projects/example/my-api-repo/do_stuff_fuzzer.cpp:22:3
    #2 0x55a83eae823d in fuzzer::Fuzzer::ExecuteCallback(unsigned char const*, unsigned long) /src/llvm-project/compiler-rt/lib/fuzzer/F
uzzerLoop.cpp:619:13
    #3 0x55a83eae7875 in fuzzer::Fuzzer::RunOne(unsigned char const*, unsigned long, bool, fuzzer::InputInfo*, bool, bool*) /src/llvm-pr
oject/compiler-rt/lib/fuzzer/FuzzerLoop.cpp:516:7
    #4 0x55a83eae9545 in fuzzer::Fuzzer::MutateAndTestOne() /src/llvm-project/compiler-rt/lib/fuzzer/FuzzerLoop.cpp:765:19
    #5 0x55a83eaea1a5 in fuzzer::Fuzzer::Loop(std::__Fuzzer::vector<fuzzer::SizedFile, std::__Fuzzer::allocator<fuzzer::SizedFile>>&) /s
rc/llvm-project/compiler-rt/lib/fuzzer/FuzzerLoop.cpp:910:5
    #6 0x55a83ead8d45 in fuzzer::FuzzerDriver(int*, char***, int (*)(unsigned char const*, unsigned long)) /src/llvm-project/compiler-rt
/lib/fuzzer/FuzzerDriver.cpp:917:6
    #7 0x55a83eb049b2 in main /src/llvm-project/compiler-rt/lib/fuzzer/FuzzerMain.cpp:20:10
    #8 0x7f2de0856082 in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x24082) (BuildId: 5792732f783158c66fb4f3756458ca24e46e827d)
    #9 0x55a83eacc09d in _start (/out/do_stuff_fuzzer+0x4e09d)

DEDUP_TOKEN: DoStuff(std::__1::basic_string<char, std::__1::char_traits<char>, std::__1::allocator<char>> const&)--LLVMFuzzerTestOneInpu
t--fuzzer::Fuzzer::ExecuteCallback(unsigned char const*, unsigned long)
0x7b5ddfe5dc44 is located 0 bytes after 20-byte region [0x7b5ddfe5dc30,0x7b5ddfe5dc44)
allocated by thread T0 here:
    #0 0x55a83ec4956d in operator new(unsigned long) /src/llvm-project/compiler-rt/lib/asan/asan_new_delete.cpp:109:35
    #1 0x55a83ec4ae78 in __libcpp_allocate<int> /usr/local/bin/../include/c++/v1/__new/allocate.h:43:28
    #2 0x55a83ec4ae78 in allocate /usr/local/bin/../include/c++/v1/__memory/allocator.h:105:14
    #3 0x55a83ec4ae78 in __allocate_at_least<std::__1::allocator<int> > /usr/local/bin/../include/c++/v1/__memory/allocate_at_least.h:41
:19
    #4 0x55a83ec4ae78 in __vallocate /usr/local/bin/../include/c++/v1/__vector/vector.h:583:25
    #5 0x55a83ec4ae78 in __init_with_size<const int *, const int *> /usr/local/bin/../include/c++/v1/__vector/vector.h:601:7
    #6 0x55a83ec4ae78 in vector /usr/local/bin/../include/c++/v1/__vector/vector.h:277:5
    #7 0x55a83ec4ae78 in DoStuff(std::__1::basic_string<char, std::__1::char_traits<char>, std::__1::allocator<char>> const&) /src/my-gi
t-repo/projects/example/my-api-repo/my_api.cpp:12:20
    #8 0x55a83ec4aaa9 in LLVMFuzzerTestOneInput /src/my-git-repo/projects/example/my-api-repo/do_stuff_fuzzer.cpp:22:3
    #9 0x55a83eae823d in fuzzer::Fuzzer::ExecuteCallback(unsigned char const*, unsigned long) /src/llvm-project/compiler-rt/lib/fuzzer/F
uzzerLoop.cpp:619:13
    #10 0x55a83eae7875 in fuzzer::Fuzzer::RunOne(unsigned char const*, unsigned long, bool, fuzzer::InputInfo*, bool, bool*) /src/llvm-p
roject/compiler-rt/lib/fuzzer/FuzzerLoop.cpp:516:7
    #11 0x55a83eae9545 in fuzzer::Fuzzer::MutateAndTestOne() /src/llvm-project/compiler-rt/lib/fuzzer/FuzzerLoop.cpp:765:19
    #12 0x55a83eaea1a5 in fuzzer::Fuzzer::Loop(std::__Fuzzer::vector<fuzzer::SizedFile, std::__Fuzzer::allocator<fuzzer::SizedFile>>&) /
src/llvm-project/compiler-rt/lib/fuzzer/FuzzerLoop.cpp:910:5
```



```
    #12 0x55a83eaea1a5 in fuzzer::Fuzzer::Loop(std::__Fuzzer::vector<fuzzer::SizedFile, std::__Fuzzer::allocator<fuzzer::SizedFile>>&) /
src/llvm-project/compiler-rt/lib/fuzzer/FuzzerLoop.cpp:910:5
    #13 0x55a83ead8d45 in fuzzer::FuzzerDriver(int*, char***, int (*)(unsigned char const*, unsigned long)) /src/llvm-project/compiler-r
t/lib/fuzzer/FuzzerDriver.cpp:917:6
    #14 0x55a83eb049b2 in main /src/llvm-project/compiler-rt/lib/fuzzer/FuzzerMain.cpp:20:10
    #15 0x7f2de0856082 in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x24082) (BuildId: 5792732f783158c66fb4f3756458ca24e46e827d
)

DEDUP_TOKEN: operator new(unsigned long)--__libcpp_allocate<int>--allocate
SUMMARY: AddressSanitizer: heap-buffer-overflow /src/my-git-repo/projects/example/my-api-repo/my_api.cpp:24:10 in DoStuff(std::__1::basi
c_string<char, std::__1::char_traits<char>, std::__1::allocator<char>> const&)
Shadow bytes around the buggy address:
  0x7b5ddfe5d980: fa fa fd fd fd fd fa fa fd fd fd fd fa fa fd fd
  0x7b5ddfe5da00: fd fa fa fa fd fd fd fd fa fa fd fd fd fa fa fa
  0x7b5ddfe5da80: fd fd fd fa fa fa fd fd fd fa fa fa fd fd fd fa
  0x7b5ddfe5db00: fa fa fd fd fd fa fa fa fd fd fd fa fa fa fd fd
  0x7b5ddfe5db80: fd fa fa fa fd fd fd fa fa fa fd fd fd fa fa fa
=>0x7b5ddfe5dc00: fd fd fd fa fa fa 00 00[04]fa fa fa fa fa fa fa
  0x7b5ddfe5dc80: fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa
  0x7b5ddfe5dd00: fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa
  0x7b5ddfe5dd80: fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa
  0x7b5ddfe5de00: fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa
  0x7b5ddfe5de80: fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa fa
Shadow byte legend (one shadow byte represents 8 application bytes):
  Addressable:           00
  Partially addressable: 01 02 03 04 05 06 07
  Heap left redzone:       fa
  Freed heap region:       fd
  Stack left redzone:      f1
  Stack mid redzone:       f2
  Stack right redzone:     f3
  Stack after return:      f5
  Stack use after scope:   f8
  Global redzone:          f9
  Global init order:       f6
  Poisoned by user:        f7
  Container overflow:      fc
  Array cookie:            ac
  Intra object redzone:    bb
  ASan internal:           fe
  Left alloca redzone:     ca
  Right alloca redzone:    cb
==14==ABORTING
MS: 5 CrossOver-PersAutoDict-PersAutoDict-ChangeByte-PersAutoDict- DE: "foo"-"bar"-"ouch"-; base unit: 5c9312ff51e77bb12a8d043e8470d9972
3411e55
0x9a,0x90,0x66,0x6f,0x6f,0x75,0x63,0x68,0x6f,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0
x66,0x66,0x6f,0x6d,0x67,0x68,0x66,0x66,0x66,0x7a,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x0,0x0,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66
,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0xe6,0x66,0x66,0x66,0x62,0x61,0x72,
0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0
x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x
66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x66,0x82,0x66,0x66,0x66,0x66,0x66,0x66,
\232\220foouchofffffffffffffffffffffomghfffzfffffff\000\000fffffffffffffffffffffffffffff\346fffbarfffffffffffffffffffffffffffffffffffffff
ffffffffffffffffffffffffff\202ffffff
artifact_prefix='./'; Test unit written to ./crash-1d69eabea4ca44c2769df8b71941f7a6b785f582
```

```
Base64: mpBmb291Y2hvZmZmZmZmZmZmZmZmZmZmZmZvbWdoZmZmemZmZmZmZmYAAGZmZmZmZmZmZmZmZmZmZmZmZmZmZmZm5mZmZmJhcmZmZmZmZmZmZm
ZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmZmgmZmZmZmZg==
```

4. Erros/Vulnerabilidades Identificadas (Análise do Crash)

A análise do Estudo de Caso 2 (*example*) permitiu identificar claramente uma vulnerabilidade de segurança:

1. **Tipo de Erro:** O AddressSanitizer (ASan) reportou um ***heap-buffer-overflow***.
2. **Causa:** O programa tentou ler 4 bytes de memória (*READ of size 4*) em um endereço que estava fora dos limites do bloco de memória alocado na *heap*.
3. **Localização Exata do Bug:** O relatório de *stack trace* nos informou exatamente onde o bug se encontra no código-fonte, facilitando a correção: *SUMMARY: AddressSanitizer: heap-buffer-overflow /src/my-git-repo/projects/example/my-api-repo/my_api.cpp:24:10 in DoStuff(std::__1::basic_string<char, std::__1::char_traits<char>, std::__1::allocator<char>> const&)*
4. **Entrada da Falha:** O fuzzer gerou e salvou automaticamente a entrada exata (o *test case*) que causou a falha. Este arquivo pode ser usado para depurar o programa: *Test unit written to ./crash-1d69eabea4ca44c2769df8b71941f7a6b785f582*

O arquivo de *crash* foi salvo pelo *helper* na máquina local, no diretório *build/out/example/*.

5. Conclusão

A atividade demonstrou com sucesso o fluxo de trabalho do fuzzing com OSS-Fuzz. Foi possível observar como o fuzzer opera tanto em um cenário estável (*tinyxml2*) quanto em um cenário vulnerável (*example*), onde ele rapidamente identificou um erro crítico de ***heap-buffer-overflow*** e forneceu todas as informações necessárias para sua depuração e correção.